Quiz — TOTP enroll / recovery

Fillable quiz — type answers in the fields. Blank copies are already under `my-work/quizzes/`; answer them in place. Answer keys are not included.

1. Why verify a live TOTP code before marking enrollment complete?

2. How should recovery codes be stored at rest in production, and **why** not plaintext?

3. Scenario: An attacker phishes one recovery code. What property of `consume_recovery` limits the damage?

4. Why track `last_used_step` — what does RFC 6238 §5.2 require after a successful OTP validation?

5. Spot the bug / why: Enrollment commits `secret = "JBSWY3DPEHPK3PXP"` into the course repo “for demos.”

6. Name one threat TOTP enroll does **not** solve that passkeys/WebAuthn address.

7. Why lock the enrollment after `MAX_FAILED_ATTEMPTS` wrong codes — what attack remains without throttle?